

SAST, DAST & SCA: The AppSec Toolchain

The three engines

Tool	What it does	Pros	Cons
SAST	Static Application Security Testing – scans source/bytecode	Fast, finds root causes, low false-ok	False positives, sees code not runtime
DAST	Dynamic – black-box tests a running app	Finds runtime/config issues, no source needed	Misses deep paths, slower
SCA	Software Composition Analysis – audits open-source deps	Finds known CVEs (A06)	Noise in huge dep trees

Plus: **IAST** (agent in the running app), **MAST** (mobile), **Secret scanning** (rotating tokens in repos).

Where they fit in CI/CD

```
commit -> [SAST + secret scan] -> build -> [SCA + SBOM] ->  
test -> [DAST on staging] -> approval gates -> deploy -> [runtime]
```

Fail the build on critical/high SAST findings

Pull-request comments so the *author* fixes it

Scan every merge, not nightly-only

SCA alerts on newly disclosed CVEs of already-shipped deps

Results management

Triage: true positive vs false positive

SLA by severity

Dedupe against prior scans (MRR – mean remediation rate)

Let developers filter "new vs existing" findings

Tooling examples

SAST: Semgrep, CodeQL, SonarQube, Fortify/Checkmarx

DAST: OWASP ZAP, Burp Pro scanner, HCL AppScan

SCA: Snyk, Dependabot, Trivy, Grype

SBOM (SBOM = Software Bill of Materials)

A machine-readable inventory of components (SPDX or CycloneDX).

Required by modern supply chain exec orders. SCA feeds the SBOM; the SBOM makes "is Log4Shell in our stack?" answerable in minutes.

[← Secure Coding: Injection, XS...](#)

[CI/CD Security & Software Supp...](#)